IGNITEFEST 2026
RED TEAM SECURITY ASSESSMENT

Web Portal | Assessment Report

Assessment target: https://csa2026.pythonanywhere.com

Assessment account: organizer role returned for the supplied student credentials

Assessment date: 4–5 November 2026

Prepared by : Pranav Sharma

1. Executive Summary

A limited-scope assessment of the IgniteFest 2026 web portal identified three material security issues. The supplied student account was returned by the login workflow with the role value “organizer” and was able to access organizer-only functionality, including statistics and a confidential committee briefing. Separately, the application’s publicly reachable backup path returned HTTP 200 to a HEAD request made from an Incognito session with credentials omitted. The response metadata identified the resource as a downloadable SQL file (application/sql; 5,793 bytes).

The backup file contents were not downloaded or inspected. The assessment therefore confirms unauthenticated access to the backup resource and its metadata, but does not claim that specific database records were extracted. The root cause of the unexpected organizer role was not established; account provisioning or backend role assignment requires investigation.

2. Scope and Rules of Engagement

In-scope target: the IgniteFest 2026 portal at csa2026.pythonanywhere.com.

Account used: only the credentials supplied for the challenge (student@college.edu).

Testing was limited to normal application navigation, inspection of browser Network responses and client-side JavaScript, and non-content-retrieving HEAD requests to the disclosed backup path. No other accounts were used. No database dump was downloaded, no other users’ registration records were deliberately accessed, and no destructive or state-changing security tests were performed.

3. Methodology

1. Authenticated to the portal using the challenge-provided student credentials.
2. Inspected the login/profile and organizer-related API responses in browser Developer Tools.
3. Reviewed the supplied client-side app.js for endpoint references and security-relevant implementation clues.
4. Observed the Organizer Hub, organizer statistics and confidential briefing returned to the authenticated session.
5. Reviewed the registrations page and one ticket record associated with the supplied account.
6. Checked the disclosed backup path with HEAD requests, first in the authenticated browser and then in Incognito with credentials omitted.

4. Findings

F-01 — Supplied student account receives organizer privileges

Severity: High (preliminary; subject to the challenge's expected account configuration and business impact).

Category: Broken access control / privilege assignment (root cause unconfirmed).

Evidence:

- The login request sent the email and password only; the client-side login function did not submit a role field.
- The login response was observed to return role: "organizer" for the supplied student account.
- The Organizer Hub was displayed and organizer-only API requests succeeded in that session.
- A profile update request containing only name, phone, college and bio returned role_changed: false; this test did not demonstrate mass assignment.
- The detailed registration record for the supplied account also showed attendee_role: "organizer".

Impact: A user intended to operate as a student was able to reach organizer functionality. This enabled access to organizer statistics and the confidential committee briefing. Depending on the actual backend permissions, the same misassignment could expose additional administrative operations.

Reproduction summary: Sign in using only the challenge-provided student credentials; inspect the login response; observe that the returned user role is organizer; then observe the Organizer Hub and organizer API requests in Network.

Root-cause limitation: The available client-side JavaScript and responses establish the unexpected role and its effects, but do not identify whether the cause is a database/account-provisioning error, authentication logic, or another backend defect.

Remediation: Correct the account's server-side role assignment; enforce deny-by-default server-side role-based access control on every organizer endpoint; derive privileges only from trusted server-side records; prevent user-controlled role updates; and add automated tests asserting that student accounts cannot access organizer resources.

F-02 — Confidential organizer briefing disclosed to the supplied account

Severity: High (preliminary).

Category: Sensitive information disclosure / broken access control.

Evidence:

- GET /api/organizer/stats returned HTTP 200 and organizer statistics, including event and staff information.
- GET /api/organizer/briefing returned HTTP 200 and a document labelled restricted / eyes only / fest core committee.
- The briefing response contained operational security information, financial logistics and the challenge evaluation flag.

Impact: Disclosure of internal event operations information could compromise physical access controls, VIP handling, event security and confidential financial arrangements. Personal details present in staff-related responses should also be treated as sensitive.

Reproduction summary: Using the supplied account's authenticated session, observe the requests to /api/organizer/stats and /api/organizer/briefing in Developer Tools → Network and record their status codes and response classifications.

Remediation: Apply server-side authorization checks to each organizer endpoint; return only the minimum fields needed by the UI; avoid embedding security codes and sensitive operational details in general API responses; audit access logs; and rotate any real credentials or access codes that may have been exposed.

F-03 — SQL backup resource accessible without session credentials

Severity: High (preliminary; content and data sensitivity not assessed).

Category: Sensitive file exposure / security misconfiguration.

Affected path: /backups/fest_backup_2026.sql

Evidence:

- The client-side app.js contained a developer note disclosing the backup path.
- An authenticated HEAD request returned HTTP 200.
- Response headers identified Content-Type: application/sql, Content-Disposition: attachment; filename="fest_backup_2026.sql", and Content-Length: 5793.
- A separate Incognito request used method HEAD with credentials: omit and returned STATUS: 200.

Impact: An unauthenticated client can reach a resource presented by the server as a SQL backup attachment. If the file contains production or staging data, this could expose personal information, credentials, tokens or other sensitive records. The contents were not retrieved, so the presence of any particular data type is not asserted.

Reproduction summary: Open the portal in an Incognito session without logging in; execute a same-origin HEAD request to /backups/fest_backup_2026.sql with credentials omitted; observe HTTP 200. The authenticated-session response headers identify the resource as a SQL attachment.

Remediation: Remove database backups from the web root and deploy artifacts; store backups in private, access-controlled storage; deny public access at the web-server layer; ensure deployment pipelines remove staging artifacts; and review whether the exposed backup was accessed. If exposure is confirmed to include secrets or personal data, rotate credentials and follow the organization's incident-response process.

Evidence limitation: A HEAD request confirms the resource's availability and metadata, not the contents. No GET/download or database inspection was performed.

5. Additional Observations — Not Confirmed Vulnerabilities

IDOR lead: app.js requests GET /api/registrations/${regId} for detailed ticket records. Only a record associated with the supplied account was inspected. No cross-user access test was performed; IDOR is therefore unconfirmed.

Mass-assignment lead: The profile handler submits name, phone, college and bio. The observed response reported role_changed: false. No role modification was demonstrated; mass assignment reported as not confirmed.

Client-side checks: The source contains a client-side closed-event registration warning and a client-side organizer-role view check. These are indicators to review, but the assessment did not establish whether the corresponding backend controls are bypassable.

Potential DOM injection: Several API-derived values are inserted using innerHTML. Exploitability was not tested and no attacker-controlled payload was demonstrated; this remains a code-review observation only.

6. Challenge Flag

`FLAG{1D0R_b4ckup_m4ss_4ss1gnm3nt_0rg_acc3ss}`

The flag was present in the confidential briefing response. Its wording suggests intended themes, but it is not treated as independent proof of IDOR or mass assignment.

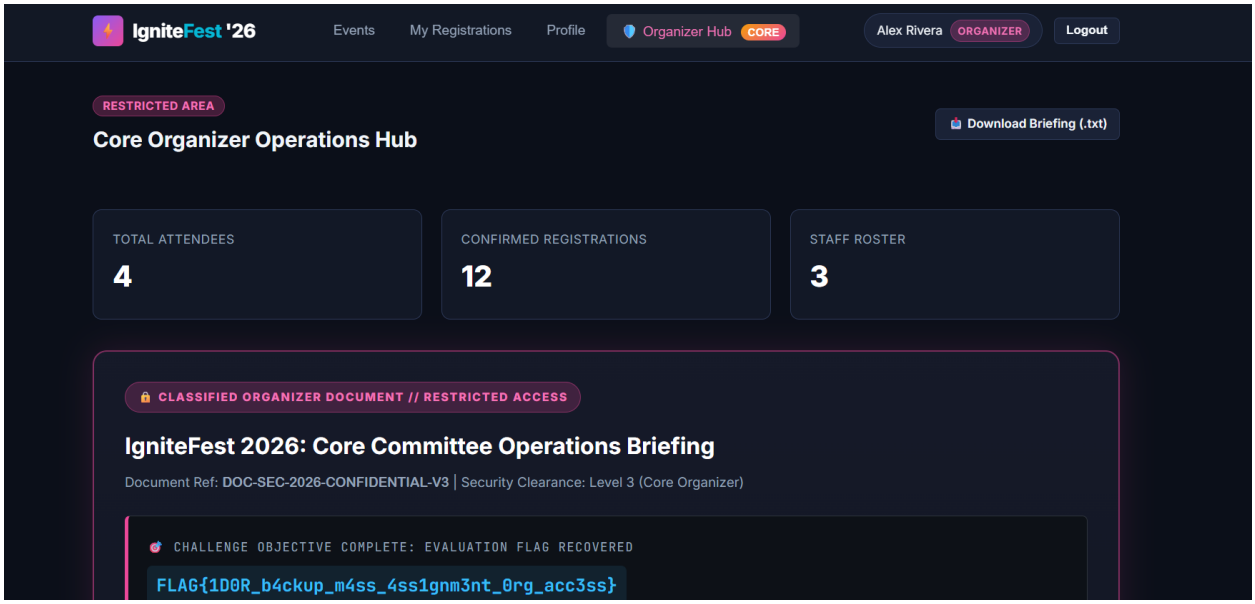
7. Overall Conclusion

The assessment confirmed that the supplied student account was granted organizer-level access and could retrieve restricted organizer information. It also confirmed that the SQL backup path responded successfully to a request made without session credentials. These issues warrant prompt review of account-role provisioning, server-side authorization and backup deployment controls. Further testing of IDOR, mass assignment and closed-event enforcement was not completed and is not represented as a confirmed result.

Appendix A — Evidence Screenshot Index

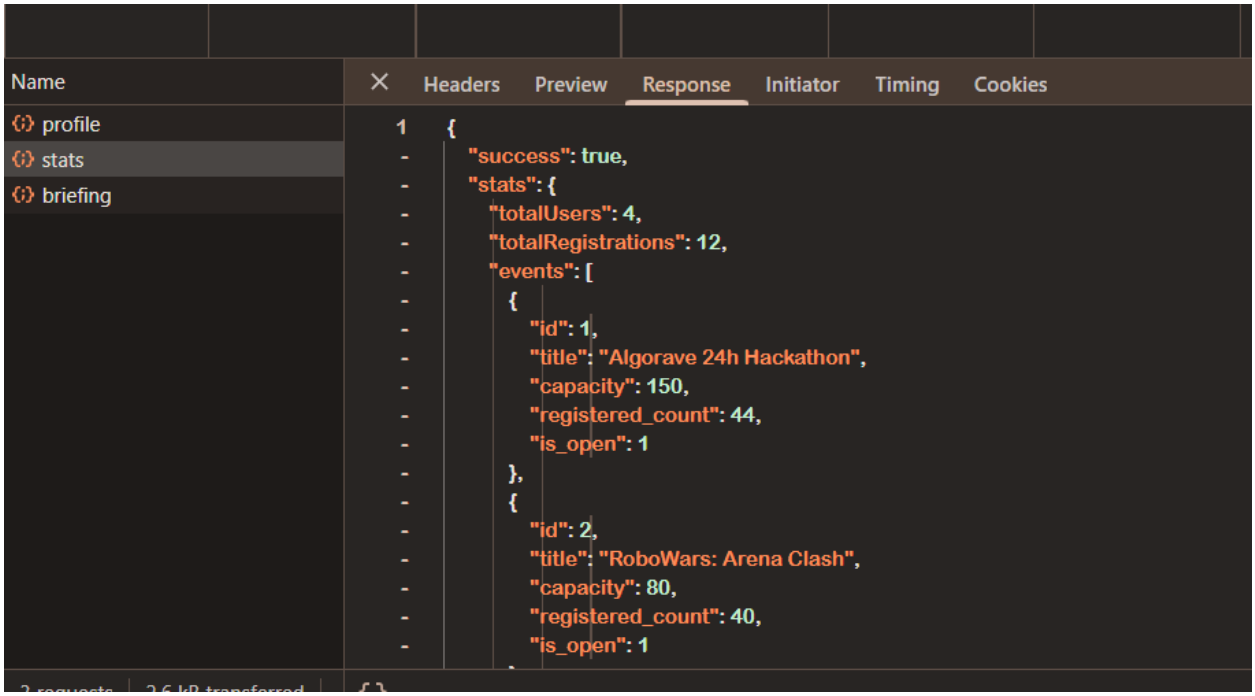
E01_organizer_hub_and_flag.png

Organizer Hub visible; restricted briefing and flag displayed in the authenticated session.



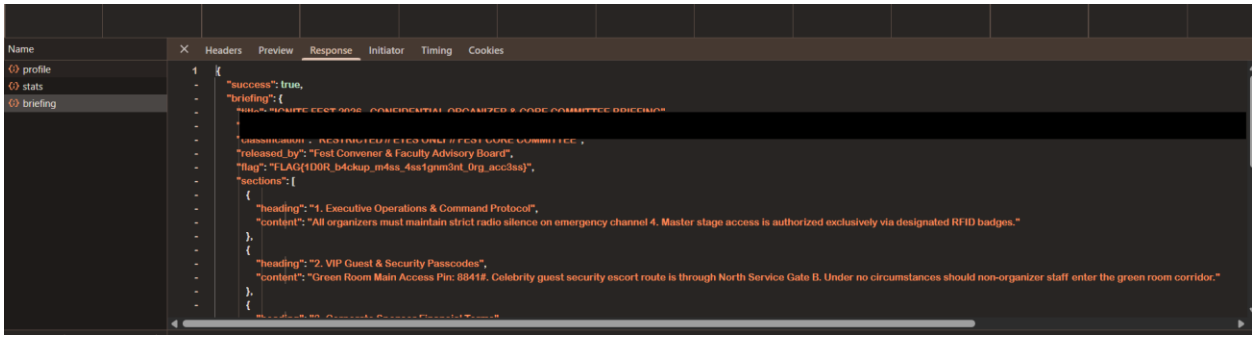
E02_organizer_stats_response.png

Network response for organizer statistics.



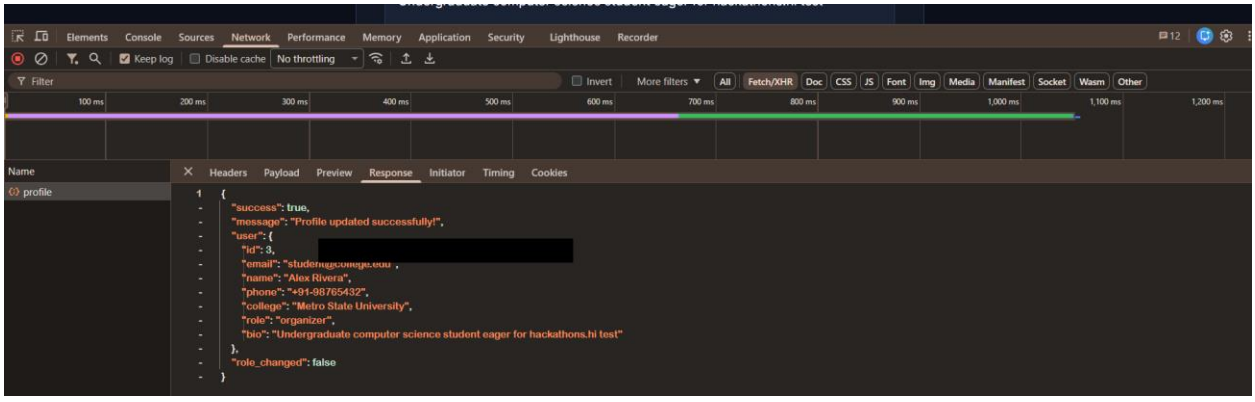
E03_briefing_response_redacted.png

Briefing API response showing document classification and flag; sensitive operational PIN line redacted.



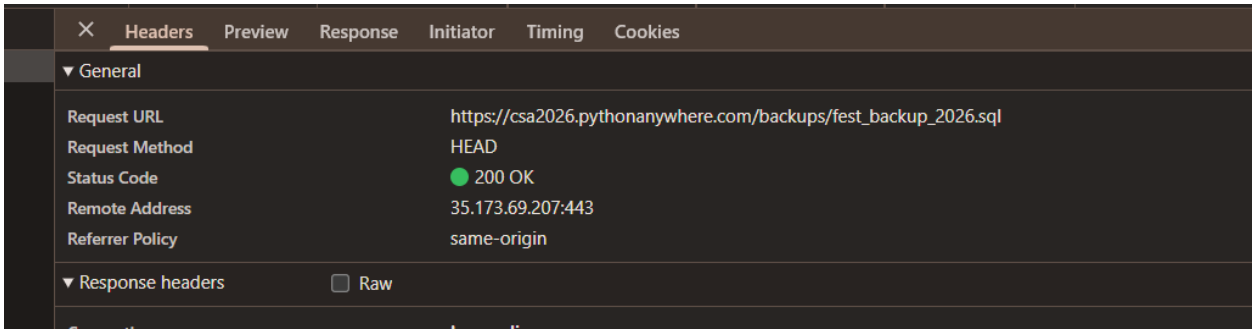
E04_profile_update_role_unchanged_redacted.png

Profile update response showing role=organizer and role_changed=false; phone value redacted.



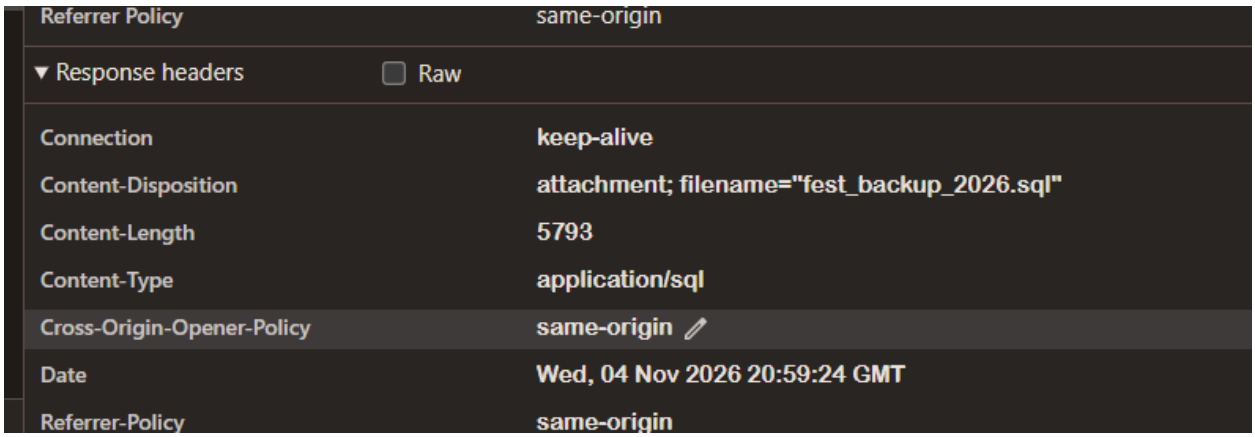
E05_backup_HEAD_status.png

Authenticated HEAD request to the disclosed backup path returning HTTP 200.



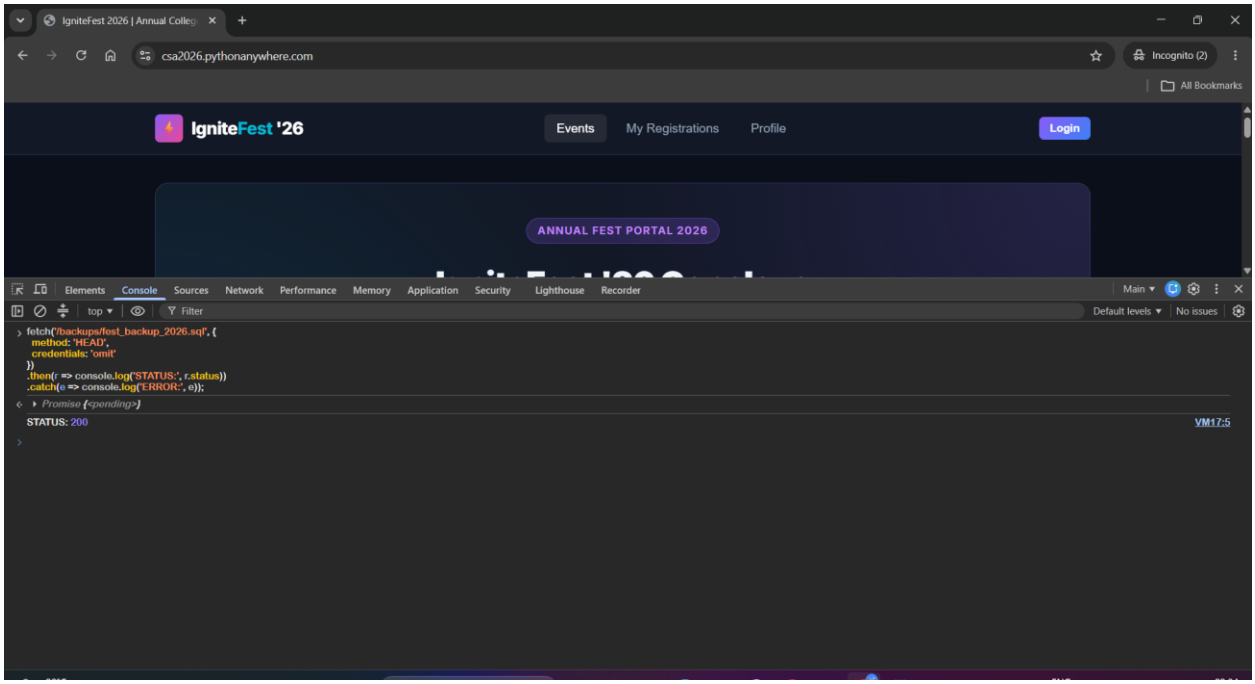
E06_backup_response_headers.png

Backup response headers identifying SQL attachment and 5,793-byte content length.



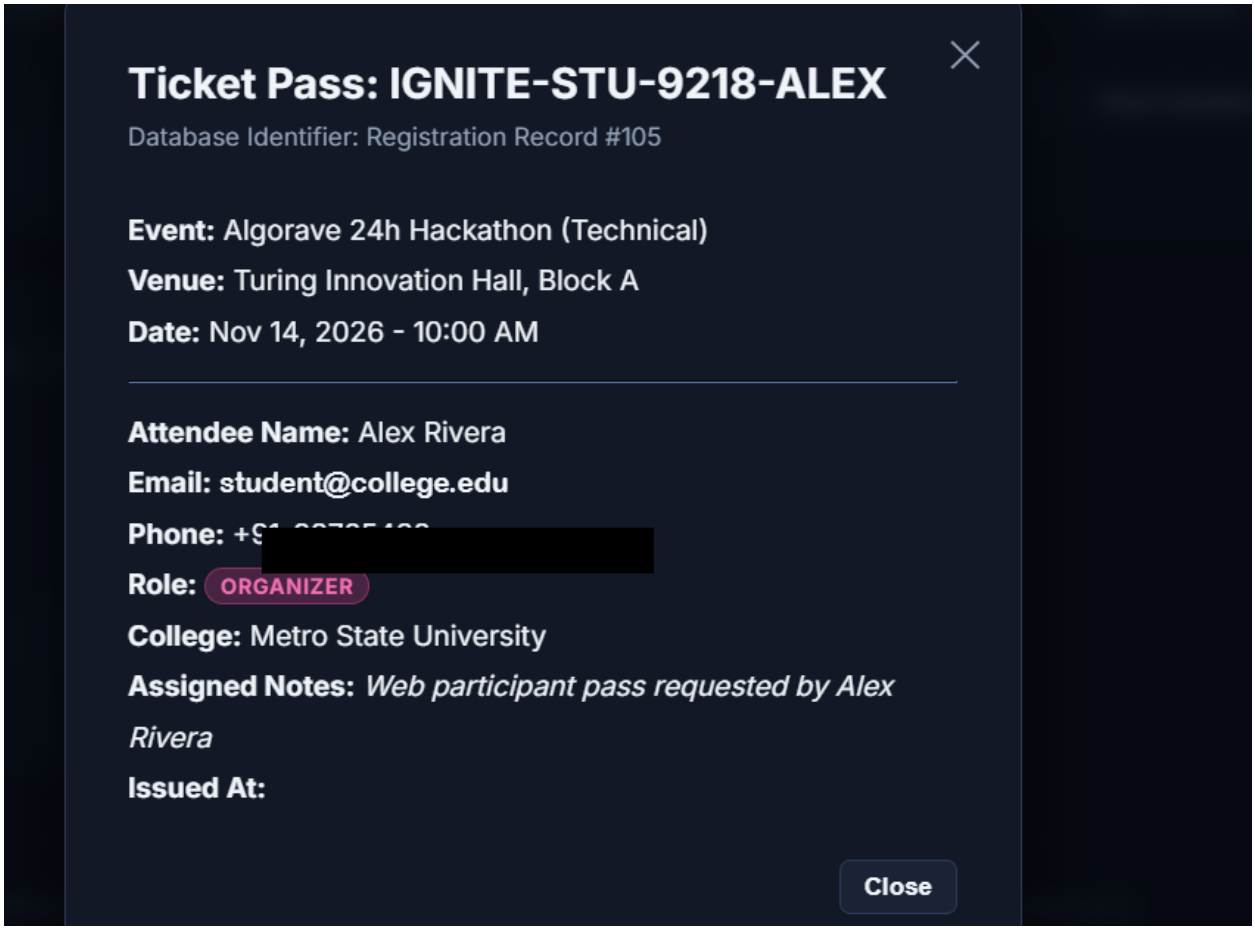
E07_incognito_unauthenticated_HEAD_200.png

Incognito, unauthenticated HEAD request with credentials omitted returning STATUS: 200.



E08_registration_record_redacted.png

Detailed registration record for the supplied account; personal phone value redacted.


Ticket Pass: IGNITE-STU-9218-ALEX
Database Identifier: Registration Record #105
Event: Algorave 24h Hackathon (Technical)
Venue: Turing Innovation Hall, Block A
Date: Nov 14, 2026 - 10:00 AM
Attendee Name: Alex Rivera
Email: student@college.edu
Phone: +9
Role: ORGANIZER
College: Metro State University
Assigned Notes: Web participant pass requested by Alex Rivera
Issued At:
Close